



USO INTERNO — DESCREVE CONTROLES DE SEGURANÇA

Documento Técnico-Funcional

Plataforma de Ensino do Coworking Social de Mudanças Globais
Ambiente Virtual de Aprendizagem

Versão	1.1 — atualiza a migração do banco para a própria VPS e o tratamento dos riscos R-01, R-03, R-04, R-05 e R-13
Data de emissão	5 de agosto de 2026
Data-base dos dados	5 de agosto de 2026
Sistema	Plataforma CSMG — <code>app.coworkingsocial.com.br</code>
Situação	Em produção desde 20/07/2026
Finalidade	Descrição funcional, técnica e de controles para fins de auditoria, prestação de contas e transferência de conhecimento
Elaboração	Equipe técnica do projeto
Classificação	Uso interno. Contém descrição de mecanismos de segurança; não contém segredos, chaves ou dados pessoais

Sumário

1. Objetivo e escopo — o que este documento cobre e o que não cobre
2. Visão geral do sistema — finalidade, perfis de usuário e porte atual
3. Arquitetura — componentes, stack, hospedagem e fluxo de requisição
4. Requisitos funcionais — catálogo RF-01 a RF-42, com rastreabilidade ao código
5. Controle de acesso — identidade, papéis, matriz de permissões e camadas de verificação
6. Modelo de dados — inventário de tabelas, funções, views e migrações
7. Segurança da informação — controles implementados e evidências
8. Privacidade e LGPD — dados tratados, finalidades, terceiros e direitos do titular
9. Integrações externas — serviços, dados trafegados e credenciais
10. Qualidade e processo de desenvolvimento — testes, revisão e versionamento
11. Operação — implantação, execução, monitoramento e continuidade
12. Requisitos não funcionais — desempenho, disponibilidade, acessibilidade
13. Riscos e limitações conhecidas — registro honesto de lacunas e plano de tratamento
14. Anexos — rotas, variáveis de ambiente, migrações, taxonomia de eventos, glossário

COMO ESTE DOCUMENTO FOI PRODUZIDO

Todo o conteúdo foi extraído por inspeção direta do código-fonte em produção, das migrações de banco aplicadas, da configuração de servidor (systemd e nginx) e de consultas de contagem ao banco. Os números de porte da base referem-se a 4 de agosto de 2026. Onde uma informação não pôde ser verificada tecnicamente a partir do ambiente, ela está marcada como **a confirmar** — e não como afirmação.

1. Objetivo e escopo

1.1 Finalidade

Este documento descreve, em nível funcional e técnico, a plataforma de ensino a distância do Coworking Social de Mudanças Globais (CSMG). Foi escrito para atender a três públicos:

- **Auditoria e prestação de contas** — evidenciar quais funcionalidades existem, quais controles de segurança e privacidade estão implementados e onde estão as lacunas conhecidas.
- **Coordenação do projeto** — dar visão completa do que foi construído, sem depender de conhecimento tácito de quem desenvolveu.
- **Continuidade técnica** — permitir que outra equipe assuma a manutenção do sistema.

1.2 Escopo

Está no escopo deste documento:

- A aplicação web (site público de inscrição, área do aluno e área administrativa) e suas rotas.
- O banco de dados, o modelo de autorização e as funções de servidor.
- As integrações com serviços externos.
- Os controles de segurança e o tratamento de dados pessoais.
- O processo de implantação e a infraestrutura de execução.

1.3 Fora de escopo

- Conteúdo pedagógico do curso (ementas, roteiros de aula, material didático) — objeto de documentação própria da coordenação.
- Contratos, custos e faturamento dos serviços de infraestrutura.
- Manual de uso da plataforma pela equipe — coberto pelo documento *Guia de Operação da Plataforma*, complementar a este.

1.4 Documentos de referência

Documento	Localização
Guia do repositório e convenções	AGENTS.md
Migrações de banco (0001 a 0022)	supabase/migrations/
Política de Privacidade publicada	/privacidade (rota pública)
Inventário de variáveis de ambiente	.env.local.example
Guia de Operação (manual da equipe)	docs/Guia-de-Operacao-Plataforma-CSMG.pdf
Roteiro de QA pré-lançamento	docs/qa-pre-lancamento.md

2. Visão geral do sistema

2.1 Finalidade de negócio

A plataforma sustenta a oferta de capacitação a distância do CSMG. Ela executa quatro processos de negócio de ponta a ponta:

1. **Captação** — página pública de divulgação com formulário de inscrição e medição da origem do tráfego.
2. **Seleção e liberação de acesso** — a coordenação libera inscrições e a plataforma dispara os convites com a matrícula.
3. **Ensino** — entrega de aulas em vídeo, materiais, avaliações corrigidas automaticamente, fórum moderado e assistente de dúvidas por IA restrito ao material do curso.
4. **Acompanhamento** — relatórios de funil de inscrição e de desempenho da turma, ficha individual do aluno e trilha de auditoria.

2.2 Perfis de usuário

Perfil	Forma de acesso	Alcance
Visitante	Anônimo	Página de divulgação, formulário de inscrição e política de privacidade.
Aluno	Conta própria (e-mail e senha)	Módulos publicados, aulas, materiais, avaliações, fórum, assistente de IA e perfil.
Monitor	Conta própria com papel de equipe	Somente as áreas administrativas cujas permissões tenham sido concedidas individualmente.
Administrador	Conta própria com papel de equipe	Todas as áreas administrativas, incluindo gestão da equipe e trilha de auditoria.
Coordenação (painel)	Senha única compartilhada, sem conta	Somente o painel de acompanhamento de inscrições, com números agregados.

2.3 Porte do ambiente produtivo

Volumes apurados por contagem direta no banco em 4 de agosto de 2026:

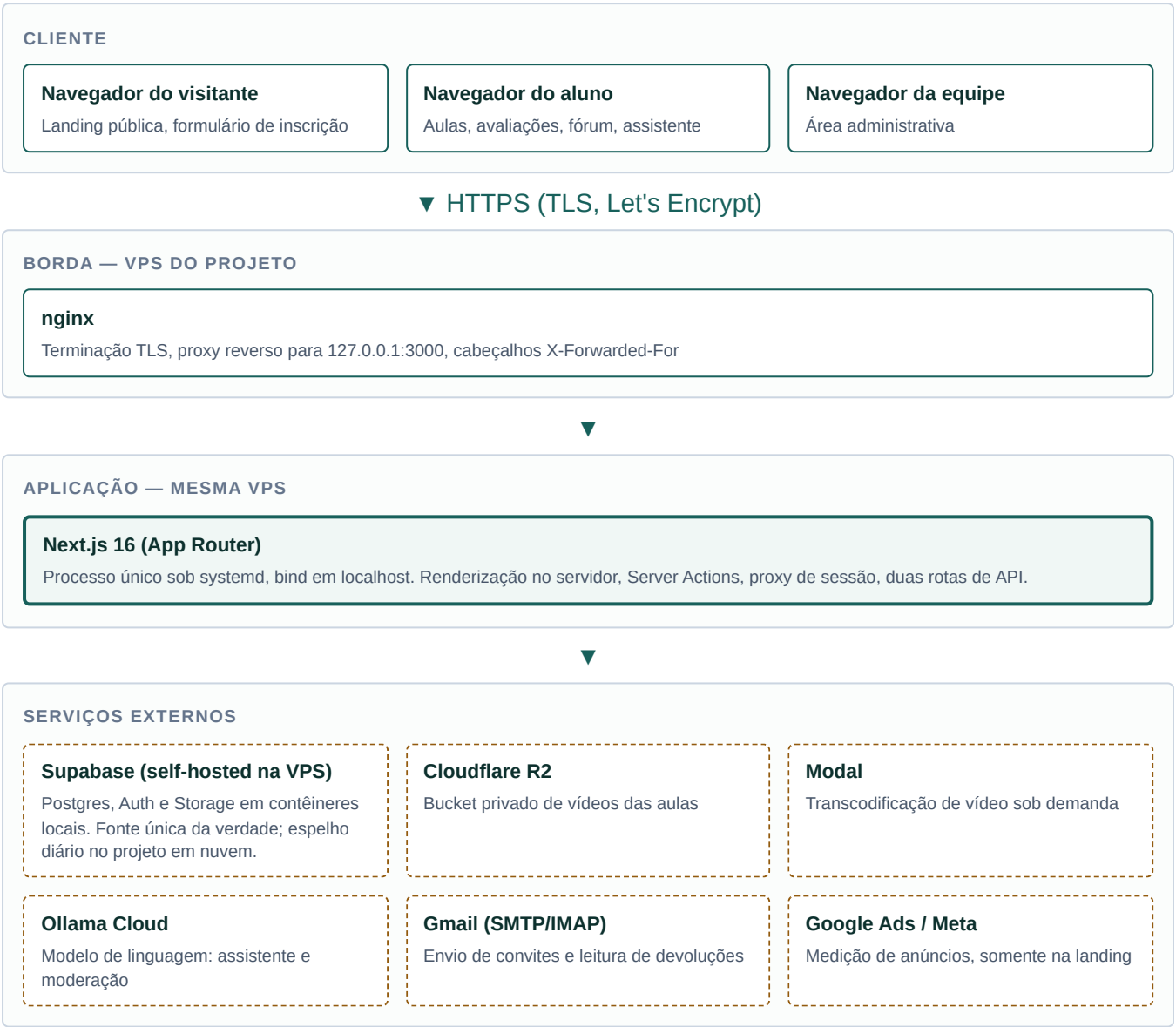
Domínio	Registros	Domínio	Registros
Inscrições	288	Aulas	32
Contas de autenticação	74	Materiais	10
— das quais equipe	8	Avaliações (questionários)	9
Módulos	13	Perguntas / alternativas	104 / 487
Disciplinas	13	Tentativas de avaliação	24
Registros de progresso	80	Trechos indexados para a IA	307
Eventos de auditoria	453	Diálogos com a IA	14
Envios de e-mail registrados	306	Visitas anônimas à landing	1.193

2.4 Ambientes

Ambiente	Descrição
Produção	VPS própria, serviço <code>coworking.service</code> atrás de <code>nginx</code> . Domínios <code>coworkingsocial.com.br</code> (divulgação) e <code>app.coworkingsocial.com.br</code> (plataforma). Desde 05/08/2026 o banco/identidade/arquivos (Supabase) rodam na própria VPS (stack self-hosted em contêineres, <code>/opt/coworking-supabase</code>); o projeto Supabase em nuvem passou a ser cópia de segurança diária.
Homologação	Stack Supabase local segregado (Supabase CLI, contêineres próprios, dados sintéticos), reconstituível do zero pelas migrações com <code>supabase db reset</code> . Toda migração de banco é testada aqui antes de ir à produção. Criado em 05/08/2026 em tratamento ao risco R-03 (ver capítulo 13).
Desenvolvimento	Máquina do desenvolvedor, <code>npm run dev</code> , apontando para o ambiente de homologação — não acessa mais o banco de produção.

3. Arquitetura

3.1 Componentes



3.2 Stack e versões

Camada	Tecnologia	Versão / observação
Runtime	Node.js	22.22.2
Framework web	Next.js (App Router)	16.2.6 — usa proxy.ts, sucessor do middleware.ts
Interface	React	19.2.4
Estilo	Tailwind CSS	4 (tokens semânticos, tema claro/escuro)
Linguagem	TypeScript	5, modo estrito
Banco / Auth / Storage	Supabase	cliente supabase-js 2.106, @supabase/ssr 0.12

Armazenamento de vídeo	Cloudflare R2 (S3 API)	AWS SDK v3 + presigner
E-mail	Nodemailer (SMTP) / ImapFlow (IMAP)	envio e checagem de devoluções
Extração de texto	unpdf, mammoth, exceljs	PDF, DOCX, XLSX para a base da IA
Testes unitários	Vitest	4.1
Testes de ponta a ponta	Playwright	1.61
Tour guiado	driver.js	1.7

3.3 Hospedagem, rede e TLS

- A aplicação roda como serviço systemd (`coworking.service`), com reinício automático em caso de falha e log em `/var/log/coworking.log`.
- O processo escuta apenas em `127.0.0.1:3000` — não é acessível diretamente da internet.
- O nginx faz a terminação TLS (certificado Let's Encrypt) e o proxy reverso, atendendo `coworkingsocial.com.br`, `www.coworkingsocial.com.br` e `app.coworkingsocial.com.br`, com redirecionamento de HTTP para HTTPS.
- O banco de dados e o armazenamento de arquivos são serviços gerenciados externos; a VPS não guarda dados de aluno em disco.

3.4 Fluxo de uma requisição autenticada

1. O navegador envia o cookie de sessão do Supabase para o nginx, que encaminha ao Next.js.
2. O `proxy.ts` renova a sessão, aplica o portão de pré-lançamento por domínio e redireciona visitantes não autenticados de rotas protegidas (`/painel`, `/modulos`, `/master`) para o login.
3. O layout da área verifica o papel e a permissão exigidos (`exigirAluno`, `exigirMaster`, `exigirPermissao`).
4. A página, executada no servidor, consulta o banco. Leituras do aluno usam o cliente com a chave pública e o cookie do usuário, de modo que as políticas de segurança de linha (RLS) do Postgres filtram os dados.
5. Ações de escrita passam por Server Actions, que revalidam permissão antes de gravar e registram o evento na trilha de auditoria.

3.5 Modelo de renderização

A aplicação é predominantemente renderizada no servidor. Componentes de cliente existem apenas onde há interação (formulários com estado, upload, chat, listas ordenáveis). Módulos sensíveis — autenticação, cliente administrativo do banco, e-mail, métricas e IA — são marcados com `import "server-only"`, o que faz a compilação falhar caso algum deles seja importado por engano em código que vai ao navegador.

4. Requisitos funcionais

Catálogo do que o sistema faz hoje, com o ator responsável e a rastreabilidade para o ponto de implementação. A coluna "Auditoria" indica se a operação gera registro na trilha de eventos.

4.1 Captação e inscrição

ID	Requisito	Ator	Implementação	Auditoria
RF-01	Publicar página de divulgação com informações do programa e formulário de inscrição	Visitante	app/(site)	—
RF-02	Registrar inscrição com nome, CPF, e-mail e telefone, validando CPF e formato dos campos no servidor	Visitante	RPC criar_inscricao	sim
RF-03	Gerar matrícula única automaticamente na inscrição	Sistema	migração 0001	—
RF-04	Enviar e-mail de confirmação com o acesso imediatamente após a inscrição	Sistema	lib/email.ts	sim
RF-05	Capturar a origem da visita (parâmetros de campanha) e vinculá-la à inscrição	Sistema	lib/origem.ts, migração 0012	—
RF-06	Contar visitas à landing de forma anônima, sem IP e sem identificador	Sistema	RPC registrar_visita, migração 0013	—
RF-07	Limitar a 10 inscrições por hora por endereço IP	Sistema	lib/limite-taxa.ts	—

4.2 Identidade e acesso

ID	Requisito	Ator	Implementação	Auditoria
RF-08	Ativar conta no primeiro acesso mediante matrícula e e-mail, com definição de senha pelo próprio titular	Aluno	/primeiro-acesso	sim
RF-09	Autenticar por e-mail e senha, com sessão renovada a cada requisição	Aluno / equipe	Supabase Auth + proxy.ts	sim
RF-10	Encerrar sessão	Aluno / equipe	(plataforma)/actions.ts	sim
RF-11	Redefinir senha por link enviado ao e-mail cadastrado	Aluno	/definir-senha	—
RF-12	Bloquear rotas protegidas para não autenticados	Sistema	proxy.ts	—

4.3 Ensino — área do aluno

ID	Requisito	Ator	Implementação	Auditoria
RF-13	Listar apenas os módulos publicados, com capa, instrutor e progresso individual	Aluno	/painel + RLS	—

RF-14	Exibir módulos não publicados como teaser "Em breve", sem expor conteúdo	Aluno	/painel	—
RF-15	Reproduzir a aula em vídeo (YouTube, URL externa ou vídeo hospedado)	Aluno	VideoPlayer, lib/r2.ts	—
RF-16	Marcar aula como assistida e atualizar o progresso	Aluno	(aluno)/actions.ts	sim
RF-17	Disponibilizar materiais de apoio da disciplina	Aluno	tabela materiais	—
RF-18	Responder avaliação de múltipla escolha com correção imediata no servidor e nota mínima configurável	Aluno	RPC corrigir_quiz	sim
RF-19	Permitir nova tentativa de avaliação, mantendo o histórico de todas	Aluno	quiz_tentativas	sim
RF-20	Coletar avaliação anônima da disciplina (estrelas e comentário) ao concluir	Aluno	migração 0022	sim
RF-21	Manter perfil do aluno (biografia e imagem)	Aluno	migração 0016	—
RF-22	Oferecer tour guiado narrado da plataforma, por perfil	Aluno / equipe	components/tour	—

4.4 Assistente de dúvidas (IA)

ID	Requisito	Ator	Implementação	Auditoria
RF-23	Responder dúvidas do aluno usando exclusivamente o material cadastrado na disciplina, sem conhecimento externo	Aluno	api/ia/chat	—
RF-24	Recuperar os trechos pertinentes por busca textual do Postgres, respeitando o RLS do aluno	Sistema	RPC buscar_chunks (invoker)	—
RF-25	Orientar a navegação na plataforma com links internos, no modo geral	Aluno	lib/ia/guia-plataforma.ts	—
RF-26	Reconstruir automaticamente o índice de trechos quando o material da disciplina muda	Sistema	lib/ia/conhecimento.ts	—
RF-27	Informar ao aluno que a resposta é gerada por IA e pode conter imprecisões	Sistema	componente de chat	—

4.5 Fórum e moderação

ID	Requisito	Ator	Implementação	Auditoria
RF-28	Publicar dúvida ou enquete no fórum, com limite de postagem por período	Aluno	lib/forum/rate-limit.ts	sim
RF-29	Submeter toda publicação a moderação prévia automatizada, mantendo pendente o que for suspeito ou não avaliado	Sistema	lib/forum/moderacao.ts	sim

RF-30	Aprovar ou rejeitar publicação pendente, com motivo visível ao autor	Equipe	/master/forum	sim
RF-31	Responder, votar e marcar resposta como solução	Aluno	migrações 0015 e 0017	sim
RF-32	Notificar o autor sobre o desfecho da moderação e sobre respostas	Sistema	lib/forum/notificacoes.ts	—

4.6 Gestão de conteúdo

ID	Requisito	Ator	Implementação	Auditoria
RF-33	Criar, editar, ordenar, publicar e excluir módulos, disciplinas, aulas, materiais e avaliações	Equipe	master/actions.ts	sim
RF-34	Agendar a publicação de um módulo para data e hora futuras	Equipe	migração 0019	sim
RF-35	Enviar arquivo de vídeo e transcodificá-lo automaticamente para 720p, publicando a versão convertida e descartando o original	Equipe	R2 + Modal + api/video/concluir	—
RF-36	Cadastrar base de conhecimento da IA por disciplina, por texto ou anexo (PDF, DOCX, XLSX, TXT, MD, CSV até 20 MB)	Equipe	lib/ia/extrair-texto.ts	sim

4.7 Gestão de alunos, convites e equipe

ID	Requisito	Ator	Implementação	Auditoria
RF-37	Buscar e filtrar inscrições por nome, e-mail, matrícula e situação, com paginação	Equipe	/master/alunos	—
RF-38	Exibir ficha individual com cadastro, histórico de convites, desempenho por disciplina e atividade recente	Equipe	/master/alunos/[id]	—
RF-39	Liberar inscrições e disparar convites em massa de forma idempotente, registrando cada envio	Equipe	lib/convites.ts, migração 0020	sim
RF-40	Identificar e-mails devolvidos por leitura da caixa postal e marcá-los para novo envio	Equipe	lib/devolucoes.ts (IMAP)	—
RF-41	Acionar contato por WhatsApp com mensagem pré-montada e registrar o contato para evitar duplicidade	Equipe	lib/whatsapp.ts	sim
RF-42	Cadastrar membros da equipe, conceder e revogar permissões individualmente e remover acesso	Administrador	master/equipe/actions.ts	sim

4.8 Relatórios e auditoria

ID	Requisito	Ator	Implementação	Auditoria
RF-43	Apresentar funil de inscrição: visitas, inscrições, variação por período e origem do tráfego	Equipe / coordenação	RPC metrics_painel	—
RF-44	Apresentar desempenho da turma por disciplina, com conclusão, aprovação e feedback anônimo	Equipe	lib/relatorios-turma.ts	—
RF-45	Disponibilizar painel de inscrições por senha única, sem conta individual	Coordenação	lib/painel-auth.ts	—
RF-46	Registrar quem fez o quê e quando, com filtros e busca, sem possibilidade de exclusão pela interface	Administrador	lib/auditoria.ts, migração 0021	sim

5. Controle de acesso

5.1 Modelo de identidade

A identidade é gerenciada pelo Supabase Auth. Cada pessoa tem uma conta individual com e-mail e senha; a senha é armazenada pelo provedor com hash e **não é acessível à equipe nem à aplicação**. A sessão é mantida por cookie e renovada a cada requisição pelo proxy .ts.

O papel do usuário fica em `app_metadata`, um espaço do token de autenticação que **somente a chave de serviço pode escrever** — o usuário não consegue alterar o próprio papel, e o valor chega assinado no token, dispensando consulta adicional ao banco.

5.2 Papéis, níveis e permissões

Quem não tem papel é aluno. Quem tem o papel `master` é equipe, e se subdivide em dois níveis: **administrador** (acesso total) e **monitor** (somente o concedido). São cinco permissões atômicas:

Permissão	Libera	Operações sensíveis alcançadas
<code>visao_aluno</code>	Navegar como aluno	Leitura do conteúdo publicado
<code>moderar_forum</code>	Aba Fórum de dúvidas	Aprovar e rejeitar publicações de terceiros
<code>editar_conteudo</code>	Aba Conteúdo	Criar, publicar e excluir conteúdo do curso
<code>ver_relatorios</code>	Aba Relatórios	Desempenho nominal por aluno
<code>gerenciar_emails</code>	Abas Alunos e E-mails	Acesso a dados pessoais e disparo de e-mail em massa

5.3 Matriz de acesso

Recurso	Visitante	Aluno	Monitor	Administrador	Painel (senha)
Landing e inscrição	✓	✓	✓	✓	—
Conteúdo publicado do curso	—	✓	se <code>visao_aluno</code>	✓	—
Progresso e notas próprios	—	✓	✓	✓	—
Progresso e notas de terceiros	—	—	se <code>ver_relatorios</code>	✓	—
Dados pessoais de inscritos	—	—	se <code>gerenciar_emails</code>	✓	—
Gestão de conteúdo	—	—	se <code>editar_conteudo</code>	✓	—
Moderação do fórum	—	—	se <code>moderar_forum</code>	✓	—
Disparo de e-mail em massa	—	—	se <code>gerenciar_emails</code>	✓	—
Gestão da equipe	—	—	—	✓	—
Trilha de auditoria	—	—	—	✓	—
Números agregados de inscrição	—	—	se <code>ver_relatorios</code>	✓	✓
Gabarito das avaliações	—	—	se <code>editar_conteudo</code>	✓	—

5.4 Verificação em camadas

A autorização não depende de um único ponto. São quatro barreiras independentes, e a falha de qualquer uma delas não é suficiente para expor dados:

Camada	Onde	O que garante
1 — Borda	proxy.ts	Sessão válida para rotas protegidas; portão de domínio.
2 — Layout	exigirAluno, exigirMaster, exigirPermissao	Papel e permissão antes de renderizar qualquer página da área.
3 — Ação	Server Actions	Revalidação da permissão dentro de cada operação de escrita — não se confia na tela ter escondido o botão.
4 — Banco	Políticas RLS do Postgres	Mesmo com consulta forjada, o banco só devolve as linhas que aquele usuário pode ver.

5.5 Painel por senha única

O painel de acompanhamento em /relatorios usa mecanismo separado: uma senha compartilhada, guardada apenas como variável de ambiente do servidor. A conferência é feita com comparação em tempo constante (evitando ataque por medição de tempo) e, quando correta, grava um cookie httpOnly com um *hash* derivado da senha — nunca a senha em si — válido por 12 horas. Trocar a senha invalida automaticamente todos os cookies emitidos. Há limite de 10 tentativas por IP a cada 15 minutos.

LIMITAÇÃO POR NATUREZA DO MECANISMO

Por não haver conta individual, o painel não permite atribuir o acesso a uma pessoa específica nem revogar o acesso de uma só pessoa. É adequado para números agregados — que é o que ele expõe — mas não deve ser estendido a dados pessoais. Ver risco R-08.

6. Modelo de dados

6.1 Inventário de tabelas

Todas as tabelas ficam no esquema `public` de um Postgres do stack Supabase self-hosted na VPS. A coluna "PD" indica presença de dado pessoal identificável.

Tabela	Linhas	PD	Finalidade e observações
<code>inscricoes</code>	288	sim	Nome, CPF, e-mail, telefone, matrícula, situação de seleção e ativação, origem da campanha. Tabela mais sensível do sistema.
<code>modulos</code>	13	não	Blocos do curso: título, instrutor, capa, ordem, publicação e agendamento.
<code>disciplinas</code>	13	não	Divisões do módulo; unidade que agrega aulas, materiais e avaliação.
<code>aulas</code>	32	não	Vídeos: provedor, identificador, situação de processamento e miniatura.
<code>materiais</code>	10	não	Links de apoio da disciplina.
<code>quizzes</code>	9	não	Avaliação da disciplina e nota mínima.
<code>quiz_perguntas</code>	104	não	Enunciados.
<code>quiz_alternativas</code>	487	não	Alternativas e gabarito (coluna correta) — nunca exposta ao cliente.
<code>quiz_tentativas</code>	24	sim	Nota, aprovação e respostas por aluno. Dado de desempenho.
<code>progresso_aula</code>	80	sim	Quais aulas cada aluno concluiu e quando.
<code>disciplina_conhecimento</code>	11	não	Material que alimenta o assistente de IA, com referência ao arquivo original.
<code>disciplina_chunks</code>	307	não	Trechos derivados do material, com índice de busca textual.
<code>ia_mensagens</code>	14	sim	Perguntas e respostas do assistente, vinculadas ao aluno.
<code>forum_posts</code>	2	sim	Publicações, situação de moderação e parecer da IA.
<code>forum_respostas</code>	0	sim	Respostas às publicações.
<code>forum_enquete_opcoes</code>	0	não	Opções das enquetes.
<code>forum_votos_posts / _respostas / _enquete</code>	3 / 0 / 0	sim	Votos por aluno. Quem votou em quê nunca é enviado ao navegador.
<code>perfis</code>	7	sim	Biografia e imagem do aluno.
<code>avaliacoes_disciplina</code>	12	sim	Estrelas e comentário. Exibido de forma anônima nos relatórios.
<code>eventos</code>	453	sim	Trilha de auditoria: ator, ação, alvo, detalhes e momento.
<code>envios_email</code>	306	sim	Registro por envio: endereço, tipo, situação e erro.
<code>visitas_landing</code>	1.193	não	Contagem anônima: só data e campanha. Sem IP e sem identificador.
<code>video_jobs</code>	2	não	Fila de transcodificação de vídeo.

6.2 Funções e views

O sistema concentra em funções de banco tudo que não pode ser decidido pelo cliente. O modo *definer* executa com os privilégios do dono da função; o modo *invoker* executa com os privilégios de quem chama, respeitando o RLS.

Objeto	Modo	Concedida a	Finalidade
criar_inscricao	definer	anônimo	Único caminho de gravação de inscrição. Valida no servidor; o papel anônimo não tem permissão de escrita direta na tabela.
corrigir_quiz	definer	autenticado	Corrige a avaliação no banco. O gabarito nunca sai do servidor.
metricas_painel	definer	somente serviço	Agregados do funil. Não é acessível pelo cliente, nem autenticado.
registrar_visita	definer	anônimo	Contagem anônima de visita à landing.
buscar_chunks	invoker	autenticado	Recuperação de material da disciplina para a IA, respeitando o RLS do aluno.
buscar_chunks_geral	invoker	autenticado	Idem, no modo geral (todas as disciplinas visíveis ao aluno).
buscar_posts_similares	invoker	autenticado	Sugestão de publicações parecidas no fórum.
quiz_alternativas_publicas (view)	—	autenticado	Expõe as alternativas sem a coluna do gabarito .
inscricoes_export (view)	invoker	revogada de anônimo e autenticado	Exportação administrativa. Ver seção 7.10.

6.3 Segurança em nível de linha

Vinte e quatro tabelas têm RLS habilitado. O padrão adotado é:

- **Conteúdo do curso** (modulos, disciplinas, aulas, materiais, quizzes, quiz_perguntas, disciplina_chunks): leitura permitida ao autenticado apenas quando o item está publicado.
- **Dados do próprio aluno** (progresso_aula, quiz_tentativas, ia_mensagens, avaliacoes_disciplina, perfis): leitura e escrita restritas a linhas onde o identificador do aluno é o do usuário autenticado.
- **Dados administrativos** (eventos, envios_email, video_jobs, inscricoes): sem política de leitura pública — só alcançáveis pela chave de serviço, no servidor.

6.4 Controle de mudança do esquema

O esquema evolui por 24 migrações versionadas no repositório (0000 a 0023), todas idempotentes e com comentário de intenção no cabeçalho. Desde 05/08/2026, toda migração é **testada primeiro no ambiente de homologação** (supabase db reset reconstrói o banco do zero na ordem) e só então aplicada em produção via `psql`, em ordem. O código foi escrito para tolerar migração ainda não aplicada: as telas afetadas exibem aviso em vez de quebrar. Ver risco R-04.

7. Segurança da informação

7.1 Segregação de credenciais de banco

O sistema usa três clientes de banco distintos, e a escolha entre eles é tratada como decisão de segurança:

Cliente	Credencial	Uso e limite
Público (anônimo)	Chave pública	Chamadas do visitante, restritas às funções concedidas ao papel anônimo.
Sessão do usuário	Chave pública + cookie	Age <i>como o usuário logado</i> ; o RLS filtra. Padrão para toda leitura do aluno.
Administrativo	Chave de serviço	Ignora o RLS. Exclusivo de servidor, protegido por <code>import "server-only"</code> , que quebra a compilação se for importado em código de navegador.

7.2 Proteção do gabarito das avaliações

A coluna que marca a alternativa correta nunca é enviada ao navegador. As alternativas chegam ao aluno por uma view sem essa coluna, e a correção acontece integralmente no banco, pela função `corrigir_quiz`. Não há caminho pelo qual inspecionar o tráfego ou o código do navegador revele a resposta certa antes da submissão.

7.3 Limitação de taxa

Alvo	Limite	Finalidade
Formulário de inscrição	10 por hora por IP	Cortar cadastro automatizado em massa, que queimaria a reputação do remetente de e-mail.
Senha do painel	10 por 15 min por IP	Impedir força bruta.
Publicação no fórum	por período, por aluno	Conter enxurrada de publicações.

O IP é lido dos cabeçalhos `X-Forwarded-For` / `X-Real-IP`, que o nginx sempre reescreve — não há proxy do usuário à frente que permita forjá-los. A contagem é mantida em memória do processo; ver risco R-02.

7.4 Autenticação de webhook

O retorno da transcodificação de vídeo é autenticado por segredo compartilhado, comparado em **tempo constante** sobre o hash de cada lado — o que impede tanto a descoberta do segredo por medição de tempo quanto o vazamento do seu comprimento. Segredo ausente ou vazio nunca confere, o que evita que uma variável de ambiente não configurada abra a porta. Além disso, a chamada só é aceita se corresponder a um envio real daquela aula.

7.5 Isolamento do serviço de transcodificação

O serviço externo que converte os vídeos recebe apenas as credenciais do bucket de armazenamento e o segredo do webhook — **nunca a chave de serviço do banco**. A atualização do banco é feita exclusivamente pela aplicação, ao receber o retorno. Um comprometimento desse serviço não dá acesso a dados de aluno.

7.6 Armazenamento e entrega de vídeo

- Bucket **privado**: nenhum vídeo é acessível por URL pública.

- O envio é feito por URL assinada de curta duração, gerada no servidor.
- A reprodução usa URL assinada de curta duração, gerada a cada carregamento da página, para o aluno autenticado.
- O arquivo original é descartado após a conversão; publica-se apenas a versão limitada a 720p.

7.7 Moderação à prova de falha

Toda publicação de aluno no fórum é avaliada por um modelo de linguagem antes de ir ao ar. O desenho é deliberadamente conservador: os vereditos *suspeito* e *erro* — este último inclui indisponibilidade do modelo e tempo esgotado — **mantêm o conteúdo pendente**, na fila de revisão humana. A IA pode destravar uma publicação, nunca liberá-la por omissão nem descartá-la sozinha.

7.8 Restrição do assistente de IA

O prompt confina o modelo ao material recuperado do banco, proíbe uso de conhecimento externo, proíbe revelar as próprias instruções e determina resposta negativa quando não há material sobre a pergunta. A recuperação de trechos usa função em modo *invoker*, ou seja, o aluno só pode recuperar material de disciplinas às quais já tem acesso — não há como extrair conteúdo de módulo não publicado por meio do assistente.

7.9 Trilha de auditoria

Treze tipos de evento são registrados hoje, cobrindo sessão, ativação de conta, inscrição, conclusão de aula, tentativa de avaliação, avaliação de disciplina, fórum, conteúdo, equipe e contato com aluno (anexo D). O registro é **à prova de falha por contrato**: uma falha ao auditar nunca interrompe a operação do usuário. Não há interface de exclusão de eventos.

CONTRAPARTIDA DO DESENHO À PROVA DE FALHA

Como a auditoria não pode quebrar o fluxo do usuário, uma falha de gravação é descartada em silêncio. Isso significa que a trilha é *altamente provável*, mas não *garantida* — ela não deve ser tratada como prova irrefutável de ausência de um fato. Ver risco R-07.

7.10 Vulnerabilidade identificada e corrigida antes do lançamento

Registro para fins de auditoria, por transparência. Durante a preparação para o lançamento identificou-se que a view `inscricoes_export` havia sido criada sem o modo *invoker*. Views em Postgres executam com os privilégios do dono e, nessa condição, ignoram o RLS da tabela por baixo — o que permitia ao papel anônimo, cuja chave é pública e embarcada no navegador, ler nome, CPF, e-mail e telefone de todos os inscritos pela API.

Item	Descrição
Correção	Migração <code>0003_seguranca_inscricoes.sql</code> , aplicada antes do lançamento.
Medida 1	A view passou a respeitar o RLS de quem consulta (<code>security_invoker</code>).
Medida 2	Defesa em profundidade: acesso à view revogado dos papéis anônimo e autenticado.
Medida 3	Removida a política que permitia inserção direta na tabela pelo papel anônimo; toda inscrição passa obrigatoriamente pela função validada.
Situação	Corrigido e verificado. A tabela em si já estava protegida por RLS; a exposição se dava apenas pela view.

7.11 Gestão de segredos

- Segredos ficam em `.env.local` na VPS, fora do controle de versão. O repositório contém apenas `.env.local.example`, sem valores.
- Convenção estrita: variáveis com prefixo `NEXT_PUBLIC_` são públicas por definição e vão ao navegador; sem o prefixo, nunca saem do servidor.
- Cada variável é lida no ponto de uso, com erro explícito quando ausente — o sistema falha de forma visível em vez de operar em estado degradado silencioso.
- Inventário completo no anexo B.

8. Privacidade e proteção de dados (LGPD)

8.1 Dados pessoais tratados

Dado	Finalidade	Origem	Onde é armazenado
Nome completo	Identificação do aluno, comunicação e certificação	Titular, na inscrição	inscricoes
CPF	Identificação unívoca e prestação de contas do programa	Titular, na inscrição	inscricoes
E-mail	Credencial de acesso e envio de convite e comunicações	Titular, na inscrição	inscricoes, provedor de identidade, envios_email
Telefone	Contato de suporte, inclusive por WhatsApp	Titular, na inscrição	inscricoes
Senha	Autenticação	Titular, no primeiro acesso	Provedor de identidade, com hash. Inacessível à equipe.
Progresso e notas	Acompanhamento pedagógico	Gerado pelo uso	progresso_aula, quiz_tentativas
Publicações no fórum	Interação pedagógica	Titular	forum_*
Diálogos com o assistente	Suporte ao estudo e melhoria do material	Titular	ia_mensagens
Registros de atividade	Segurança, auditoria e suporte	Gerado pelo uso	eventos
Origem da campanha	Medição de eficácia da divulgação	Parâmetros do link	inscricoes, visitas_landing

8.2 Minimização e anonimização — medidas adotadas

- **Visitas à landing são anônimas:** registram-se apenas data e campanha. Não há endereço IP, identificador de visitante nem cookie de rastreamento próprio.
- **Feedback de disciplina é anônimo na exibição:** o vínculo com o aluno existe apenas para impedir voto duplicado; os relatórios mostram somente estrelas e comentário.
- **Votos do fórum não trafegam:** as leituras agregadas são feitas no servidor; quem votou em quê nunca chega ao navegador.
- **O painel por senha expõe apenas números agregados,** nunca registros individuais.
- **Dentro da área do aluno não há nenhum rastreador de terceiros.**
- **Logs sem conteúdo de dado pessoal:** os registros do serviço documentam a operação da aplicação, não o conteúdo dos dados. Desde 05/08/2026 os dados pessoais residem em disco na VPS (banco self-hosted e cópias de segurança, ambos em diretórios restritos ao root) — a afirmação anterior desta seção, de que não havia dado pessoal em disco na VPS, valia para a arquitetura com banco em nuvem.

8.3 Cookies e ferramentas de terceiros

Ferramenta	Onde atua	Dado enviado
------------	-----------	--------------

Tag do Google Ads	Somente na landing pública	Visita e conversão de inscrição. Não recebe nome, e-mail, CPF ou telefone.
Pixel da Meta	Somente na landing pública	Visita e conversão de inscrição. Não recebe nome, e-mail, CPF ou telefone.
Cookies próprios	Plataforma	Sessão de login (essencial) e preferências de tema e som, guardadas no navegador.

Ambas as ferramentas estão declaradas na Política de Privacidade publicada em /privacidade, com a informação de que podem ser bloqueadas pelo navegador sem prejuízo à inscrição ou ao curso.

8.4 Operadores e subprocessadores

Serviço	Papel no tratamento	Dados a que tem acesso
Supabase (nuvem)	Desde 05/08/2026, apenas cópia de segurança (espelho diário do banco, contas e arquivos)	Todos os dados pessoais tratados pelo sistema, na condição de réplica
Provedor da VPS	Hospedagem da aplicação e do banco de dados (stack Supabase self-hosted desde 05/08/2026)	Todos os dados pessoais tratados pelo sistema, em disco e em memória
Google (Gmail)	Envio de e-mail e leitura de devoluções	Nome, e-mail e matrícula, no corpo das mensagens
Cloudflare R2	Armazenamento de vídeo	Somente conteúdo do curso — nenhum dado pessoal
Modal	Conversão de vídeo	Somente arquivos de vídeo do curso
Ollama Cloud	Modelo de linguagem	Texto da pergunta do aluno e trechos do material; recebe o conteúdo da publicação na moderação
Google Ads e Meta	Medição de anúncios	Evento de visita e conversão na landing, sem dados de identificação

A CONFIRMAR

A região de armazenamento dos dados no provedor de banco e a existência de cláusulas de transferência internacional não são verificáveis a partir do código e devem ser confirmadas junto à coordenação, com os contratos dos serviços. Ver risco R-11.

8.5 Direitos do titular

A Política de Privacidade publicada informa que o titular pode solicitar acesso, correção ou exclusão dos seus dados, bem como informações sobre o tratamento, pelos canais oficiais do CSMG. Operacionalmente, o atendimento é viável com as ferramentas existentes:

Direito	Como é atendido hoje
Confirmação e acesso	Ficha individual do aluno na área administrativa reúne cadastro, convites, desempenho e atividade.

Correção	Alteração do cadastro pela equipe administrativa.
Eliminação	Exclusão da conta e da inscrição; registros dependentes caem por integridade referencial. Procedimento executado manualmente.
Portabilidade	Exportação administrativa das inscrições pelo painel do provedor de banco.
Informação sobre compartilhamento	Seção 8.4 deste documento e Política de Privacidade.

LACUNA

Não há hoje um procedimento formal escrito, com prazo e responsável designado, para o atendimento de requisições de titular, nem tela dedicada a isso. Ver risco R-09.

8.6 Retenção e descarte

O sistema não implementa expurgo automático. Todos os registros permanecem enquanto a base existir. Não há política formal de retenção definida por tipo de dado. Ver risco R-10.

9. Integrações externas

Serviço	Função no sistema	Credencial usada	Dado trafegado	Comportamento em caso de falha
Supabase (self-hosted)	Banco, identidade e arquivos — contêineres na própria VPS desde 05/08/2026; o projeto em nuvem recebe espelho diário (cópia de segurança)	Chave pública e chave de serviço, geradas localmente	Todos os dados do sistema (não saem mais da VPS na operação normal)	Indisponibilidade total da plataforma; recuperável pelo espelho em nuvem.
Gmail SMTP	Envio de convites e notificações	Usuário e senha de aplicativo	Nome, e-mail, matrícula e link de acesso	Envio registrado como falha; reprocessável no disparo seguinte.
Gmail IMAP	Leitura de devoluções	Mesma credencial	Cabeçalhos das devoluções	Devolução não detectada; nenhuma perda de dado.
Ollama Cloud	Assistente e moderação do fórum	Chave de API	Pergunta do aluno, trechos do material, texto da publicação	Assistente indisponível; moderação mantém a publicação pendente para revisão humana.
Cloudflare R2	Armazenamento de vídeo	Chave de acesso S3	Arquivos de vídeo do curso	Aulas com vídeo próprio não reproduzem; aulas com link externo seguem normalmente.
Modal	Transcodificação sob demanda	URL do endpoint e segredo compartilhado	Arquivos de vídeo	Aula permanece em processamento; nada é publicado pela metade.
Google Ads	Medição de anúncio	Identificador público de conversão	Evento de visita e conversão	Sem impacto funcional.
Meta	Medição de anúncio	Identificador público do pixel	Evento de visita e conversão	Sem impacto funcional.
ElevenLabs	Geração da narração do tour	Chave de API	Texto dos passos do tour	Não é usado em execução: os áudios são gerados offline e servidos como arquivos estáticos.

OBSERVAÇÃO SOBRE DEPENDÊNCIA DE IA

Nenhuma decisão com efeito irreversível é delegada ao modelo de linguagem. Ele sugere (moderação) e responde consultas (assistente); a aprovação de conteúdo e qualquer alteração de dado dependem de ação humana ou de código determinístico.

10. Qualidade e processo de desenvolvimento

10.1 Estratégia de testes

O projeto adota desenvolvimento orientado a testes como regra: o teste é escrito antes do código. A cobertura é distribuída por camada:

Camada	Ferramenta	O que cobre
Lógica pura e regras de negócio	Vitest	Validação de CPF e telefone, permissões, cálculo de progresso e relatórios, normalização de auditoria, limite de taxa, comparação de segredos, ordenação, conversão de datas, origem de tráfego, devoluções.
Componentes de interface	Vitest + Testing Library	Comportamento de formulários e componentes interativos.
Fluxos de usuário	Playwright	Inscrição, primeiro acesso, login, navegação de aula e avaliação, fórum, perfil, níveis de acesso da equipe, assistente.

10.2 Resultado da suíte na data-base

Métrica	Valor
Arquivos de teste unitário e de componente	40
Casos de teste	202, todos aprovados
Tempo de execução da suíte	aproximadamente 26 segundos
Especificações de ponta a ponta	8 arquivos
Análise estática	ESLint e TypeScript em modo estrito

Os testes de ponta a ponta rodam contra o banco real e criam apenas dados identificáveis (endereços em domínio de exemplo), removidos automaticamente ao final da execução. Especificações que dependem de recurso ausente são puladas em vez de falharem.

10.3 Versionamento e controle de mudança

- Repositório Git, com commits atômicos — um assunto por commit, cada um compilando e passando nos testes isoladamente.
- Mensagens em formato convencional (feat, fix, chore, docs, test, refactor), o que torna o histórico auditável por tipo de mudança.
- Colaboradores sem permissão de escrita trabalham por bifurcação do repositório e requisição de incorporação; colaboradores com permissão integram diretamente, sempre com testes verdes.
- Convenção de idioma única (português) para código, nomes e comentários, reduzindo ambiguidade na manutenção.

11. Operação

11.1 Implantação

A implantação é feita por script único (`scripts/deploy.sh`), executado na VPS, com troca atômica:

1. A nova versão é construída em diretório separado, com a produção no ar e intacta.
2. O serviço é parado, o diretório antigo é substituído pelo novo e o serviço é reiniciado — janela de indisponibilidade de aproximadamente 2 segundos.
3. Verificação automática de saúde: a rota de login precisa responder com sucesso, caso contrário o script termina com erro sinalizado.

MOTIVO DO DESENHO

Construir a nova versão sobre a que está sendo servida faz com que usuários carregando páginas durante a construção recebam referências a arquivos que deixaram de existir — página sem estilo. A troca atômica elimina essa janela.

11.2 Execução e registros

Item	Configuração
Gerenciador de processo	systemd, unidade <code>coworking.service</code>
Reinício automático	Sim, com intervalo de 5 segundos
Escuta	<code>127.0.0.1:3000</code> — sem exposição direta
Registros	<code>/var/log/coworking.log</code> (saída padrão e de erro)
Usuário do processo	<code>root</code> — ver risco R-06

11.3 Monitoramento

Desde 05/08/2026, um vigia local (`scripts/vigiar-producao.sh`, cron a cada 5 minutos) confere a resposta da plataforma e o espaço em disco; duas falhas seguidas disparam alerta por e-mail à operação (no máximo um por hora). Limitação conhecida: o vigia mora na própria VPS — se a máquina inteira cair, o alerta cai junto; a contratação de verificação externa de disponibilidade permanece recomendada. Não há agregação de erros da aplicação. Ver risco R-05.

11.4 Continuidade e recuperação

Ativo	Situação da proteção
Código-fonte	Versionado em repositório Git remoto. Recuperável.
Esquema do banco	Reconstituível pelas 24 migrações versionadas (validado: o ambiente de homologação é recriado do zero por elas).
Dados do banco	Três camadas desde 05/08/2026: dump local diário (03:30, retenção de 14, teste de restauração executado e registrado em <code>docs/backups-e-monitoramento.md</code>); espelho diário completo no projeto Supabase em nuvem (04:00 — banco, contas e arquivos); e snapshot da VPS no provedor (ativação a confirmar no painel).

Vídeos das aulas	Armazenados no bucket; o arquivo original é descartado após a conversão. Sem cópia secundária.
Configuração do servidor	nginx e systemd sem cópia versionada fora da VPS; a configuração do stack Supabase local reside em /opt/coworking-supabase (o compose vem de repositório público; o .env de segredos não é versionado).

Ponto de recuperação efetivo: até 24 horas (espelho diário). Objetivo de tempo de recuperação ainda não formalizado; o procedimento de retorno à nuvem está documentado em docs/migracao-banco-vps.md e leva minutos. Ver risco R-01.

12. Requisitos não funcionais

Atributo	Como é atendido
Desempenho	Renderização no servidor com consultas paralelas por página; listas com paginação (25 alunos, 50 eventos por página); vídeo limitado a 720p para reduzir consumo de banda do aluno.
Escalabilidade	Banco na própria VPS (16 GB / 4 núcleos, uso corrente ~30%); aplicação em processo único — ver risco R-02 quanto ao efeito sobre a limitação de taxa. A latência de API caiu de 0,7–1,3 s (nuvem, plano gratuito) para ~10 ms (local), medida em 05/08/2026.
Disponibilidade	Reinício automático do serviço; deploy com indisponibilidade de aproximadamente 2 segundos e verificação de saúde.
Compatibilidade	Aplicação web responsiva, sem instalação, funcionando em navegadores modernos de computador e celular.
Acessibilidade	Marcação semântica, rótulos associados aos campos, foco visível, contraste de cores em tema claro e escuro, e respeito à preferência do sistema por redução de animações.
Usabilidade	Tour guiado narrado por perfil, assistente de dúvidas contextual, estados vazios ilustrados e mensagens de erro em linguagem comum.
Internacionalização	Sistema monolíngue em português do Brasil, com datas e números no fuso e formato locais.
Manutenibilidade	Convenção de idioma única, módulos pequenos com responsabilidade definida, marcação explícita do que é código de servidor, e cobertura de testes na lógica de negócio.

13. Riscos e limitações conhecidas

Registro deliberadamente franco das lacunas identificadas, com recomendação de tratamento. Nenhum dos itens abaixo impede a operação atual; todos são relevantes para a continuidade e para a conformidade.

ID	Risco	Severidade	Situação atual	Recomendação
R-01	Cópia de segurança dos dados não verificada	Tratado em 05/08/2026	Três camadas próprias: dump diário local com retenção de 14 e teste de restauração executado e registrado; espelho diário completo (banco, contas e arquivos) no projeto Supabase em nuvem; snapshot da VPS no provedor (ativação a confirmar). Falha de qualquer rotina dispara alerta por e-mail. Ponto de recuperação: até 24 h.	Ativar o snapshot no painel do provedor; repetir o teste de restauração a cada trimestre (roteiro em docs/backups-e-monitoramento.md).
R-02	Limitação de taxa em memória do processo	Média	Os contadores zeram a cada reinício e não são compartilhados entre processos. Adequado ao desenho atual, de processo único.	Ao adotar mais de um processo ou servidor, migrar a contagem para o banco ou para armazenamento compartilhado.
R-03	Ausência de ambiente de homologação	Tratado em 05/08/2026	Stack Supabase local segregado na VPS (contêineres próprios, dados sintéticos), reconstituível do zero pelas migrações. O desenvolvimento não acessa mais o banco de produção.	Manter o hábito: dado real não entra na homologação; fluxo novo passa por lá antes de produção (docs/homologacao.md).
R-04	Migrações aplicadas manualmente	Média — mitigado	A aplicação em produção segue manual (via <code>psql</code>), mas desde 05/08/2026 toda migração é validada antes no ambiente de homologação, que reconstrói o banco do zero na ordem — o que detecta migração fora de ordem ou dependência implícita. Sem registro automático do que foi aplicado.	Adotar aplicação automatizada com controle de versão do esquema, ou manter registro assinado de cada aplicação.
R-05	Sem monitoramento nem alerta	Média — mitigado	Vigia local a cada 5 minutos (resposta da plataforma + disco) com alerta por e-mail desde 05/08/2026. Limite: roda na própria VPS — queda total da máquina não gera alerta. Sem agregação de erros.	Contratar verificação externa de disponibilidade com alerta, e agregação de erros da aplicação.
R-06	Serviço executado como superusuário	Média	A unidade <code>systemd</code> roda como <code>root</code> , o que amplia o alcance de uma eventual exploração da aplicação.	Criar usuário dedicado sem privilégios, com permissão apenas sobre o diretório da aplicação.
R-07	Auditoria pode perder evento em silêncio	Baixa	Decisão consciente: a auditoria nunca interrompe o fluxo do usuário, então uma falha de gravação é descartada.	Registrar as falhas de auditoria no log da aplicação, para que sejam ao menos observáveis.

R-08	Painel protegido por senha compartilhada	Baixa	Sem conta individual, não há como atribuir acesso a uma pessoa nem revogar individualmente. Expõe apenas números agregados.	Manter o painel restrito a agregados. Se algum dia precisar exibir dado individual, migrar para conta com permissão.
R-09	Sem procedimento formal para requisições de titular	Média	Os direitos são atendíveis com as ferramentas existentes, mas não há responsável designado, prazo definido nem registro das solicitações.	Formalizar o procedimento com responsável, prazo e livro de registro das requisições atendidas.
R-10	Sem política de retenção e descarte	Média	Nenhum dado é expurgado automaticamente; tudo permanece indefinidamente.	Definir prazo de retenção por tipo de dado, considerando a finalidade do programa, e implementar o expurgo.
R-11	Transferência internacional não documentada	Média	A região de armazenamento nos provedores e as cláusulas contratuais aplicáveis não foram verificadas.	Levantar a região de cada serviço e anexar as cláusulas de transferência aos documentos do programa.
R-12	Entregabilidade do e-mail de convite	Alta	Os convites saem de uma conta comum de e-mail, sem domínio próprio autenticado, o que faz parte das mensagens ser classificada como spam. Mitigado por contato por WhatsApp e por aviso nas telas.	Migrar para provedor transacional com domínio próprio e autenticação de remetente configurada no DNS.
R-13	Segredos residentes na VPS	Média — mitigado	Arquivos de segredo com permissão restrita ao root (600) desde 05/08/2026. As chaves do stack local foram geradas na própria VPS e nunca transitaram por canal externo. Sem rotação periódica formal; a senha do banco em nuvem (hoje só cópia de segurança) tem rotação recomendada e pendente.	Estabelecer rotação periódica de chaves e registrar a data de cada rotação em docs/backups-e-monitoramento.md.
R-14	Dependência de terceiros sem alternativa	Baixa	Com o banco/identidade/arquivos na própria VPS (05/08/2026), a indisponibilidade que derruba a plataforma inteira passou a ser a da VPS — mitigada pelo espelho diário em nuvem, que permite retorno ao provedor anterior em minutos. IA, vídeo e e-mail seguem em serviços externos distintos, com falhas degradando funções específicas.	Documentar o plano de contingência por serviço e manter cópia externa dos vídeos publicados.

LEITURA GERAL

Os controles de *confidencialidade* — segregação de credenciais, segurança em nível de linha, proteção do gabarito, moderação conservadora, isolamento do serviço de vídeo e trilha de auditoria — estão implementados e verificáveis no código. Em 05/08/2026 foram tratadas as principais lacunas de *disponibilidade* apontadas na versão 1.0: cópia de segurança em três camadas com teste de restauração, monitoramento com alerta e segregação de ambientes (homologação local). As pendências concentram-se agora em *entregabilidade de e-mail* (R-12, com prazo prático: o disparo de convites da turma 2 em 17/08) e *governança de dados* (R-09 a R-11): formalização de procedimentos LGPD, retenção e transferência internacional. É nessa direção que o esforço seguinte tende a render mais.

14. Anexos

Anexo A — Inventário de rotas

Rota	Acesso	Função
/	Público	Divulgação e inscrição
/inscricao-realizada	Público	Confirmação da inscrição
/privacidade	Público	Política de Privacidade
/login	Público	Autenticação
/primeiro-acesso	Público	Ativação de conta
/definir-senha	Público com token	Redefinição de senha
/painel	Aluno	Lista de módulos e progresso
/modulos/[modulo]	Aluno	Disciplinas do módulo
/modulos/[modulo]/[disciplina]	Aluno	Aulas, materiais, avaliação e assistente
/forum, /forum/novo, /forum/[id]	Aluno	Fórum de dúvidas
/perfil, /perfil/[id]	Aluno	Perfil próprio e de colegas
/master	Permissão de conteúdo	Gestão de módulos
/master/modulos/[id]	Permissão de conteúdo	Edição de módulo e disciplinas
/master/disciplinas/[id]	Permissão de conteúdo	Aulas, materiais, base da IA e avaliação
/master/alunos, /master/alunos/[id]	Permissão de e-mails	Gestão e ficha de alunos
/master/emails	Permissão de e-mails	Convites em massa e registro de envios
/master/forum	Permissão de moderação	Fila de moderação
/master/relatorios	Permissão de relatórios	Funil e desempenho da turma
/master/equipe	Administrador	Gestão da equipe e permissões
/master/eventos	Administrador	Trilha de auditoria
/relatorios	Senha única	Painel de inscrições
/api/ia/chat	Aluno autenticado	Assistente, resposta em fluxo contínuo
/api/video/concluir	Segredo compartilhado	Retorno da transcodificação

Anexo B — Variáveis de ambiente

Variável	Exposição	Finalidade
NEXT_PUBLIC_SUPABASE_URL	Pública	Endereço do projeto de banco
NEXT_PUBLIC_SUPABASE_ANON_KEY	Pública	Chave de acesso limitada pelas políticas
SUPABASE_SERVICE_ROLE_KEY	Secreta	Operações privilegiadas; ignora as políticas de acesso
NEXT_PUBLIC_SITE_URL	Pública	Endereço canônico da divulgação
DOMINIO_LANDING	Servidor	Domínio que serve só a divulgação
PLATAFORMA_LIBERADA	Servidor	Chave de liberação da plataforma no domínio principal
PAINEL_SENHA	Secreta	Senha única do painel de inscrições
EMAIL_USER	Servidor	Remetente das mensagens
EMAIL_APP_PASSWORD	Secreta	Senha de aplicativo do remetente
OLLAMA_API_KEY	Secreta	Acesso ao modelo de linguagem
OLLAMA_BASE_URL, OLLAMA_MODEL, OLLAMA_THINK	Servidor	Endereço, modelo e modo de raciocínio
R2_ACCOUNT_ID, R2_BUCKET_VIDEOS	Servidor	Identificação do armazenamento de vídeo
R2_ACCESS_KEY_ID, R2_SECRET_ACCESS_KEY	Secretas	Credenciais do armazenamento
MODAL_TRANSCODE_URL	Servidor	Endereço do serviço de conversão
VIDEO_WEBHOOK_SECRET	Secreta	Autenticação mútua do retorno de conversão
ELEVENLABS_API_KEY	Secreta	Uso exclusivo em script offline; não é lida em execução

Anexo C — Migrações do banco

Nº	Assunto	Nº	Assunto
0001	Matrícula e inscrição	0012	Origem do tráfego
0002	Estrutura de ensino e correção de avaliação	0013	Contagem anônima de visitas
0003	Correção de exposição de dados pessoais	0014	Funil dos relatórios
0004	Métricas do painel	0015	Fórum de dúvidas
0005	Disciplinas	0016	Perfis de aluno
0006	Dados de demonstração	0017	Edição no fórum
0007	Correção das alternativas públicas	0018	Capa dos módulos
0008	Base de conhecimento e busca da IA	0019	Agendamento de publicação
0009	Arquivos da base de conhecimento	0020	Registro de envios de e-mail

0010	Busca geral da IA	0021	Trilha de auditoria
0011	Vídeo das aulas	0022	Feedback de disciplina

Anexo D — Taxonomia da trilha de auditoria

Tipos de evento registrados e volume acumulado na data-base:

Ação	Volume	Significado
inscricao.criada	97	Nova inscrição pela landing
sessao.login	86	Entrada na plataforma
sessao.logout	11	Saída da plataforma
conta.ativada	64	Primeiro acesso concluído
aula.assistida	75	Aula marcada como concluída
quiz.tentativa	21	Avaliação respondida
disciplina.avaliada	13	Feedback de disciplina enviado
forum.post_criado	1	Publicação no fórum
contato.whatsapp	62	Equipe acionou contato com aluno
conteudo.modulo_salvo	5	Módulo criado ou alterado
conteudo.modulos_reordenados	10	Ordem dos módulos alterada
equipe.monitor_criado	1	Membro da equipe cadastrado
equipe.permissoes_alteradas	7	Permissões concedidas ou revogadas

A taxonomia prevê ainda eventos de moderação, edição no fórum e resposta, ainda sem ocorrência registrada na data-base.

Anexo E — Glossário técnico

Termo	Significado neste documento
RLS (segurança em nível de linha)	Recurso do Postgres que filtra, dentro do próprio banco, quais linhas cada usuário pode ler ou gravar.
Modo <i>definer</i> / <i>invoker</i>	Função de banco que executa com os privilégios de quem a criou ou de quem a chama, respectivamente.
Chave de serviço	Credencial que ignora as políticas de acesso do banco. Uso exclusivo de servidor.
Server Action	Função que roda no servidor, acionada por um formulário, sem exposição de endpoint público.
URL assinada	Endereço temporário que autoriza acesso a um arquivo privado por tempo limitado.
Comparação em tempo constante	Verificação de segredo cujo tempo de resposta não depende de quantos caracteres coincidem, impedindo descoberta por medição.

Idempotente	Operação que pode ser repetida sem gerar efeito duplicado — caso do disparo de convites e das migrações.
Trecho indexado (<i>chunk</i>)	Fragmento do material da disciplina, com índice de busca, usado para embasar as respostas do assistente.
Fail-safe (à prova de falha)	Desenho em que a falha leva ao estado mais seguro — aqui, manter a publicação pendente e não interromper o usuário.

ENCERRAMENTO

Este documento reflete o estado do sistema em 4 de agosto de 2026. Cada afirmação técnica corresponde a código, configuração ou dado verificável no ambiente descrito. Alterações relevantes na arquitetura, no modelo de dados ou nos controles de segurança devem gerar nova versão deste documento.